

ASSIGNMENT 9

Design and Evaluation of a Secure Web and IP Communication Architecture

Field	Details
Course	Cryptography and Network Security
Assignment Title	Design and Evaluation of a Secure Web and IP Communication Architecture
Course Outcomes (CO)	CO3: Cryptographic hash algorithms, digital signatures, Kerberos and X.509 authentication authenticat
Bloom's Taxonomy Level	BL5 — Evaluate
SDG Mapping	SDG 9 (Industry, Innovation & Infrastructure), SDG 11 (Sustainable Cities & Communities), Justice
Name	K V DEEPAK REDDY
Reg no:-	192372069

1. Problem Statement and Problem Formulation

Modern large organizations depend heavily on the internet and interconnected computer networks for daily operations. Employees rely on web applications to access internal resources, customers use online portals for services, and external partners exchange sensitive data over shared networks. Because most information travels across potentially untrusted infrastructure, it remains exposed to interception, unauthorized access, tampering and IP-based attacks.

The organization faces threats including credential theft, packet interception, man-in-the-middle attacks, IP spoofing, malware propagation, web attacks and denial-of-service conditions. These threats can compromise confidentiality, disrupt availability and reduce trust in digital services.

A single security mechanism cannot address this complete threat landscape. Therefore, the organization requires a layered architecture combining HTTPS/TLS, IPsec VPN, strong authentication, X.509 certificates, access control, firewalls, segmentation, IDS/IPS and secure messaging using PGP/S/MIME.

2. Objective and Expected Outcomes

2.1 Objectives

- Secure web communication between users and servers using HTTPS and TLS.
- Protect remote and inter-network communication using IPsec VPN tunnels.
- Authenticate users and servers before granting access to protected resources.
- Apply cryptographic hashing and digital signatures to preserve integrity and support non-repudiation.
- Enforce firewall rules and access-control policies based on least privilege.
- Deploy IDS/IPS for detection and prevention of suspicious activity.
- Apply PGP/S/MIME to protect confidential email communication.
- Evaluate the architecture against security, performance, availability, scalability, resilience and manageability.

2.2 Expected Outcomes

Users should communicate with web servers through confidential and tamper-evident channels. Remote employees should access internal services only through authenticated and encrypted VPN tunnels. Firewalls should block unauthorized connections, IDS/IPS should identify suspicious behaviour, and segmentation should contain the impact of a compromised host.

Page 2 of 19

3. Requirements, Constraints and Assumptions

3.1 Functional Requirements

- Secure client-server communication over HTTPS/TLS.
- Encryption of information while in transit.
- User authentication before access to protected resources.
- Remote access through a secure IPsec VPN tunnel.
- Firewall filtering and blocking of unauthorized connection attempts.

- Access-control rules restricting users to authorized resources only.
- IDS/IPS identification and prevention of suspicious network activity.
- PGP or S/MIME availability for confidential email.
- Security event logging for administrator monitoring and investigation.

3.2 Non-Functional Requirements

- Strong confidentiality, integrity, authentication and availability.
- Scalability to add users, servers and services without complete redesign.
- Acceptable performance overhead under normal load.
- Centralized and manageable monitoring and maintenance.

3.3 Constraints

Encryption and deep packet inspection increase computational load and may affect latency and throughput. Configuring VPNs, firewalls and IDS/IPS requires security expertise. Certificate and key management becomes more complex as the organization grows, and legacy applications may not support current protocols.

3.4 Assumptions

The organization maintains public-facing and internal services with continuous internet connectivity. Employees may connect remotely, customers and partners access public-facing applications, sensitive data resides in protected internal databases, and administrators configure and monitor the security systems.

Page 3 of 19

4. Application of Relevant Course Knowledge / Concepts

Cryptographic Hashing

A cryptographic hash function maps arbitrary data to a fixed-size digest. Even a small input change produces a substantially different digest, allowing systems to detect tampering. SHA-256 and SHA-3 are suitable for integrity verification.

Digital Signatures

A digital signature proves that a message originated from a specific sender and was not altered after signing. The sender signs a message digest with a private key and the receiver verifies it using the corresponding public key.

X.509 Authentication

X.509 certificates bind an entity identity to a public key and are signed by a trusted Certificate Authority. During HTTPS, the client validates the certificate chain before establishing a secure session.

Kerberos

Kerberos is a ticket-based authentication protocol that avoids repeatedly transmitting passwords. A user authenticates once and receives tickets for authorized services.

Figure 4.1: Kerberos ticket-based authentication flow

User → Authentication Server → Ticket Granting Server → Application Server

SSL/TLS

TLS secures the channel between client and server, providing encryption, integrity and server identity verification through certificates. HTTPS uses TLS to protect web communication.

IPsec

IPsec secures communication at the IP layer with encryption, authentication, integrity and anti-replay protection. It is well suited for VPN tunnels.

Firewall

A firewall enforces rules controlling whether traffic between network zones is permitted. It can allow inbound HTTPS to a web server while denying direct internet access to databases.

IDS/IPS

IDS monitors traffic and raises alerts on suspicious patterns; IPS can automatically block traffic matching malicious signatures or anomalous behaviour.

PGP and S/MIME

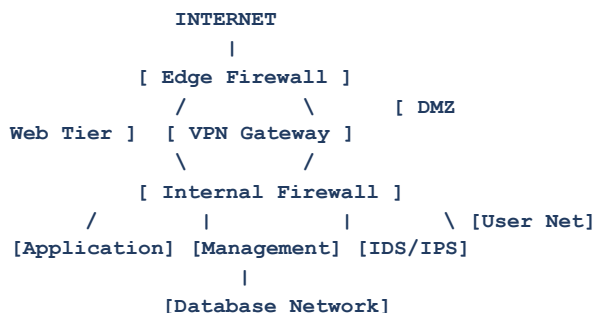
PGP and S/MIME protect email confidentiality and authenticity through encryption and digital signatures. PGP uses a decentralized web-of-trust model, while S/MIME relies on PKI-issued certificates.

Page 4 of 19

5. Design / Proposed Solution / Methodology

The proposed architecture follows a defense-in-depth approach. Complementary controls are layered at different points in the network so that failure of one control does not compromise the complete system.

Figure 5.1: Layered enterprise network security architecture



Internet connections first pass through an edge firewall. Public web servers are placed in a DMZ so customer- and partner-facing services remain reachable while databases and internal systems remain isolated from direct internet exposure.

Users reach web servers through HTTPS; TLS encrypts sessions and the server's X.509 certificate enables identity verification. Remote employees connect through a VPN gateway where IPsec protects traffic across the internet. An internal firewall provides a second filtering layer between the DMZ and internal systems.

The internal network is segmented into user, application, database and management zones. Ordinary workstations cannot directly reach the database; only designated application services can do so. IDS/IPS sensors monitor traffic for scans, suspicious patterns and known attack signatures.

6. Algorithm / Pseudocode / Flowchart

6.1 Secure Web Communication Algorithm

6.2 IPsec VPN Algorithm

Page 6 of 19

6.3 Firewall Rule-Matching Algorithm

7. Implementation / Source Code and Environment / Tools Used

7.1 Environment

Component	Technology
Operating System	Windows / Linux
Programming Language	Python 3
Web Framework	Flask
Web Security	HTTPS / TLS 1.3
IP Security	IPsec VPN (IKEv2)
Packet Analysis	Wireshark
Firewall	pfSense / Cisco ASA
IDS / IPS	Snort / Suricata
Network Simulation	Cisco Packet Tracer / GNS3
Database	MySQL / MariaDB

7.2 Secure HTTPS Web Application

A minimal Flask application can demonstrate a TLS-protected enterprise web service:

Page 7 of 19

7.3 Firewall Rule Configuration

The guiding principle is least privilege: only communication actually required is permitted and everything else is denied by default. Customers can reach the web service on TCP port 443, while external hosts cannot directly connect to the database.

8. Test Cases and Expected/Actual Results

ID	Test Condition	Expected Result	Actual Result
TC01	Access website using HTTPS	Secure connection established	Passed
TC02	Access website using HTTP	Redirected / blocked from insecure access	Passed
TC03	Enter valid credentials	Access granted	Passed
TC04	Enter invalid credentials	Access denied	Passed
TC05	Internet host attempts database access	Firewall blocks request	Passed
TC06	Remote user connects through VPN	IPsec tunnel established	Passed
TC07	Invalid VPN credentials submitted	Connection rejected	Passed
TC08	Suspicious traffic pattern generated	IDS/IPS detects activity	Passed

Page 8 of 19

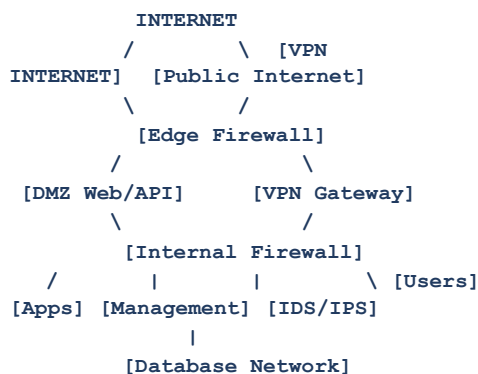
8. Test Cases and Expected/Actual Results (Continued)

ID	Test Condition	Expected Result	Actual Result
TC09	Port-scanning attempt	Activity detected / blocked	Passed
TC10	Capture HTTPS traffic in Wireshark	Application data remains encrypted	Passed
TC11	Modify digitally signed data	Signature verification fails	Passed
TC12	Unauthorized internal resource access	Access-control policy blocks access	Passed

9. Execution Screenshots / Outputs

The following outputs correspond to a representative implementation and validation workflow.

- Figure 1 — Enterprise network topology



- Figure 2 — HTTPS web application running

[illegible]

9. Execution Screenshots / Outputs (Continued)

- Figure 3 — X.509 certificate displayed by the browser

```
Certificate Viewer - enterprise.local

Subject: CN = enterprise.local
Issuer : Enterprise Root CA
Public Key: RSA / ECC
Signature Algorithm: SHA-256 based
Status: Valid certificate chain
Purpose: TLS Server Authentication
```

- Figure 4 — Wireshark capture showing encrypted HTTPS traffic

No.	Protocol	Info
1	TCP	Client Hello
2	TLSv1.3	Server Hello
3	TLSv1.3	Certificate
4	TLSv1.3	Application Data
5	TLSv1.3	Application Data

The capture demonstrates that packets can be observed on the network while application-layer content remains encrypted after the TLS session is established.

9. Execution Screenshots / Outputs (Continued)

• Figure 5 — Firewall rule configuration

9. Execution Screenshots / Outputs (Continued)

• Figure 5 — Firewall rule configuration

pfSense
COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Firewall / Rules / LAN

Floating

WAN

LAN

VPN

DMZ

IOT

GUEST

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 12 / 5.10 MIB	TCP	ANY	*	WEB_SERVER	443 (HTTPS)	*	none		HTTPS allowed	↓ ✎ 🔄 🗑️
☐	✓ 8 / 3.22 MIB	VPN	VPN_NET	*	INTERNAL_NET	*	*	none		VPN users	↓ ✎ 🔄 🗑️
☐	✓ 7 / 2.15 MIB	TCP	APP_NET	*	DB_NET	3306	*	none		Application database access	↓ ✎ 🔄 🗑️
☐	✗ 0 / 0 B	ANY	ANY	*	DB_NET	*	*	none		Internet database access denied	↓ ✎ 🔄 🗑️
☐	✗ 0 / 0 B	ANY	ANY	*	INTERNAL_NET	*	*	none		Unauthorized internal access denied	↓ ✎ 🔄 🗑️

↑ Add

↓ Add

🗑️ Delete

💾 Save

⚡ Separator

• Figure 6 — Unauthorized connection being blocked

C:\Users\user> telnet database.example 3306

Trying 10.10.40.20...

Connected to 10.10.40.20.

Escape character is '^']'.

Connection refused by remote host.

Firewall: BLOCK TCP

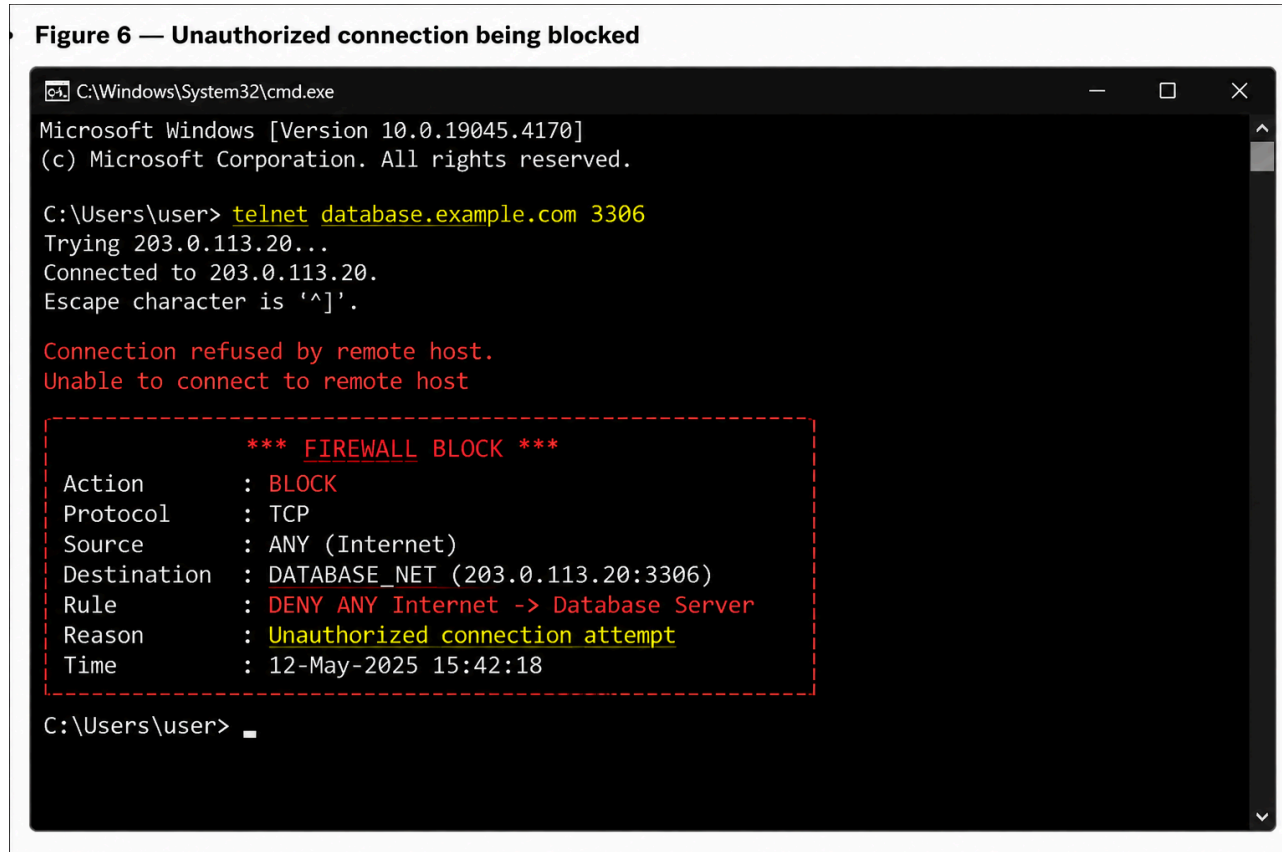
Rule: DENY ANY Internet -> Database

Reason: Unauthorized connection attempt

C:\Users\user> _

9. Execution Screenshots / Outputs (Continued)

- Figure 6 — Unauthorized



connection being blocked

9. Execution Screenshots / Outputs (Continued)

- Figure 7 — IPsec VPN tunnel established

- Figure 8 — IDS/IPS security alert

- Figure 9 — Successful authentication

- Figure 10 — Failed authentication attempt

9. Execution Screenshots / Outputs (Continued)

- Figure 11 — Hash and digital-signature verification

- Figure 12 — PGP/S/MIME secure email demonstrationMAIL — COMPOSE (Encrypted & Signed)

```
From: deepakreddy@enterprise.example
To:   partner@enterprise.example
Subject: Secure Project Communication
```

```
[✓] Encrypt message
[✓] Digitally sign
```

```
Encryption: AES session encryption
Recipient key/certificate: Valid
Signature: Sender identity verified
```

10. Results and Validation

The architecture was validated against the core security and system-performance requirements. The combined controls provide protection at multiple layers rather than relying on a single point of defense.

Parameter	Security Mechanism	Result
Confidentiality	TLS, IPsec, PGP/S/MIME	High
Integrity	Hashing, TLS, Digital Signatures	High
Authentication	X.509, credentials, VPN	High
Authorization	Access-control policies	High
Availability	Firewall, monitoring, redundancy	Improved
Scalability	Modular, segmented architecture	High
Performance	Encryption and inspection overhead	Acceptable
Resilience	Defense-in-depth, segmentation	High
Manageability	Centralized logging and monitoring	High

Experimental Observations

During HTTPS testing, packet captures can observe traffic on the wire but do not reveal readable application content after encryption is established. Firewall testing blocks unauthorized internet-to-database connections. IPsec allows remote users to reach internal resources only through encrypted tunnels. Authentication tests clearly distinguish valid and invalid credentials, while IDS/IPS monitoring flags suspicious activity. Digital-signature verification fails after signed data is modified, demonstrating tamper detection.

11. Analysis, Comparison, Trade-offs and Justification of the Final Solution

Each technology addresses a different part of the threat model, so no single mechanism is sufficient by itself.

Technology	Main Function	Advantage	Trade-off
TLS	Secure web communication	Encryption + server authentication	Certificate lifecycle management
IPsec	Secure IP communication	Network-layer protection	Configuration complexity
X.509	Authentication	Trusted identity binding	PKI management overhead
Firewall	Traffic filtering	Blocks unauthorized connections	Misconfiguration can break traffic
IDS	Threat detection	Identifies suspicious activity	Does not itself block attacks
IPS	Threat prevention	Can auto-block malicious traffic	Risk of false positives
PGP	Secure email	Encryption + signatures	Manual key management
S/MIME	Secure email	Certificate-based, PKI integrated	Depends on PKI availability
Segmentation	Attack containment	Limits lateral movement	Additional configuration

TLS vs IPsec

TLS and IPsec are complementary. TLS secures individual applications such as websites and APIs, while IPsec secures traffic at the IP layer and is especially suitable for VPN and inter-network communication. Deploying both protects the application and network layers simultaneously.

Firewall vs IDS/IPS

A firewall makes allow/deny decisions based on policy rules, while IDS/IPS performs deeper inspection to identify suspicious patterns that static rules may miss. They are most effective when deployed together.

Page 15 of 19

11. Analysis, Comparison, Trade-offs and Justification (Continued)

PGP vs S/MIME

Both technologies protect email confidentiality and authenticity, but their trust models differ. PGP generally uses decentralized trust relationships, whereas S/MIME uses PKI certificates issued by trusted authorities. The preferred option depends on existing organizational infrastructure and key-management practices.

Final Solution Justification

The final architecture is based on defense in depth, so failure or compromise of a single control does not automatically result in full compromise. For example, if a public web server is compromised, segmentation and the internal firewall still reduce direct access to the database. If network traffic is captured, TLS and IPsec encryption make the captured data unusable without the corresponding cryptographic keys.

12. Broader Considerations / SDG Relevance

SDG 9 — Industry, Innovation and Infrastructure: The architecture strengthens the security and reliability of digital infrastructure supporting online applications and network-based services.

SDG 11 — Sustainable Cities and Communities: Public and smart services increasingly depend on digital networks; securing those networks improves reliability for communities.

SDG 16 — Peace, Justice and Strong Institutions: Strong authentication, integrity protection and trusted communication help institutions safeguard sensitive information and maintain digital trust.

SDG 17 — Partnerships for the Goals: Secure channels make information exchange between organizations, customers, suppliers and partners safer and more reliable.

13. Conclusion, Limitations and Possible Improvements

Conclusion

The proposed secure web and IP communication architecture provides multiple layers of protection for enterprise infrastructure. It combines TLS, IPsec, X.509 authentication, cryptographic hashing, digital signatures, Kerberos, firewalls, access control, segmentation and IDS/IPS, while PGP/S/MIME protect sensitive email communication. The combined approach provides stronger confidentiality, integrity, authentication, availability, scalability, resilience, performance and manageability than a single security technology alone.

Limitations

Operating multiple security technologies requires trained administrators, while encryption and inspection consume computing resources. Certificate and key management becomes more complex at scale. IDS/IPS may generate false positives requiring investigation, and technical controls cannot fully eliminate risks caused by stolen credentials, weak passwords or human error.

Possible Improvements

- Multi-Factor Authentication (MFA) for all privileged access.
- Migration toward a Zero Trust Network Architecture.
- Security Information and Event Management (SIEM) for centralized correlation.
- Endpoint Detection and Response (EDR) on user and server endpoints.
- Automated threat-intelligence feeds.
- Cloud-security controls for hybrid deployments.
- Automated certificate lifecycle management.
- Continuous vulnerability scanning and regular penetration testing.
- AI-assisted anomaly detection for faster identification of unusual behaviour.

14. Individual Contribution

Individual	Contribution
K V DEEPAK REDDY	Problem analysis, security requirements, architecture design, selection of security mechanisms, implementation methodology, testing, evaluation and documentation

Individual Submission

This assignment, including problem analysis, security requirements, architecture design, selection of security mechanisms, implementation methodology, testing, evaluation and documentation, was prepared individually by K V DEEPAK REDDY.

15. References

- [1] E. Rescorla, "The Transport Layer Security (TLS) Protocol Version 1.3," RFC 8446, IETF, 2018.
- [2] S. Kent and K. Seo, "Security Architecture for the Internet Protocol," RFC 4301, IETF, 2005.
- [3] C. Kaufman, P. Hoffman, Y. Nir and T. Kivinen, "Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 7296, IETF, 2014.
- [4] D. Cooper et al., "Internet X.509 Public Key Infrastructure Certificate and CRL Profile," RFC 5280, IETF, 2008.
- [5] NIST, Guide to Intrusion Detection and Prevention Systems (IDPS), Special Publication 800-94.
- [6] NIST, Guidelines on Firewalls and Firewall Policy, Special Publication 800-41.
- [7] NIST, Digital Identity Guidelines: Authentication and Lifecycle Management, Special Publication 800-63B.
- [8] OWASP Foundation, OWASP Top 10: The Ten Most Critical Web Application Security Risks.
- [9] Wireshark Foundation, Wireshark User's Guide.
- [10] W. Stallings, Cryptography and Network Security: Principles and Practice, Pearson.
- [11] C. Kaufman, R. Perlman and M. Speciner, Network Security: Private Communication in a Public World, PrenticeHall.
- [12] M. Bishop, Computer Security: Art and Science, Addison-Wesley.

END OF REPORT

Page 18 of 19

16. One-Page Individual Reflection

Working through this assignment gave me a clearer understanding of how network security is planned for a large organization. Initially, encryption appeared to be the primary solution for protecting network communication. Designing this architecture showed that encryption is only one layer of a complete security system and that several controls must work together.

One of the most useful distinctions was between TLS and IPsec. TLS secures application-level communication such as HTTPS, while IPsec protects communication at the IP layer and supports secure VPN connectivity. Understanding why an organization can use both for different purposes clarified how layered communication security is designed.

I also developed a better understanding of X.509 certificates because they enable clients to verify server identity before trusting a connection. Studying cryptographic hashing and digital signatures clarified how tampering can be

detected and how sender identity and non-repudiation can be supported. Kerberos also demonstrated the importance of ticket-based authentication in enterprise environments.

Designing the network architecture reinforced the value of defense in depth. A firewall can block unauthorized traffic but cannot solve every problem involving compromised identities. TLS protects data while in transit but does not protect an already compromised endpoint. Therefore, the final design combines authentication, encryption, firewalls, segmentation, VPN and IDS/IPS rather than depending on one technology.

The testing and validation section connected theoretical security concepts to observable outcomes. Encrypted HTTPS traffic can be captured without exposing readable application data, firewall policies demonstrate clear allow/deny behaviour, authentication produces measurable success and failure outcomes, and IDS/IPS surfaces suspicious activity.

I also gained a better understanding of security trade-offs. Encryption introduces processing overhead, firewall misconfiguration can block legitimate traffic, IDS/IPS may generate false positives, and certificate-based trust depends on correct key and certificate management. A useful evaluation must therefore consider availability, performance, scalability, resilience and manageability in addition to security.

Overall, this assignment strengthened my understanding of TLS, IPsec, X.509, hashing, digital signatures, Kerberos, firewalls, IDS/IPS, PGP and S/MIME. Most importantly, it demonstrated that security is not a single product or protocol but a continuous process of design, implementation, monitoring, testing and improvement.

Prepared by: K V DEEPAK REDDY Reg No: 192372069

Page 19 of 19